Controls and compliance (Security Audit) - Rayane Merlin

Controls assessment checklist

Yes	No	Control	*Explanation*
☐	☑	Least Privilege	*Declared as not implemented yet*
☐	☑	Disaster recovery plans	
☑	☐	Password policies	*Nominal policies but existing*
☐	☑	Separation of duties	*Declared as not implemented yet*
☑	☐	Firewall	*Configured based on a generic set of rules*
☐	☑	Intrusion detection system (IDS)	*Not installed yet*
☐	☑	Backups	*No backups available*
☑	☐	Antivirus software	*Exists and regularly monitored by IT dep*
☑	☐	Manual monitoring, maintenance, and intervention for legacy systems	
☐	☑	Encryption	*Not currently used*
☐	☑	Password management system	*Not existing currently, can have a great economy impact because time is spent by IT dep by responding to tickets of recovering passwords*

☐	☑	Locks (offices, storefront, warehouse)	*Sufficient in all current stores*
☑	☐	Closed-circuit television (CCTV) surveillance	
☑	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)	

Compliance checklist

Select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	***Explanation***
☑	☐	Only authorized users have access to customers’ credit card information.	*Encryption isn’t set for CC storage, but Confidentiality is ensured*
☑	☐	Credit card information is accepted, processed, transmitted, and stored internally, in a secure environment.	*Process done within the internal database*
☐	☑	Implement data encryption procedures to better secure credit card transaction touchpoints and data.	No encryption currently set up
☑	☐	Adopt secure password management policies.	*Nominal but existing*

General Data Protection Regulation (GDPR)

Yes	No	Best practice	*Explanation*
☐	☐	E.U. customers' data is kept private/secured.	
☑	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.	
☐	☐	Ensure data is properly classified and inventoried.	
☑	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.	

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice	*Explanation*
☐	☑	User access policies are established.	*Least privilege policy not satisfied yet*
☐	☑	Sensitive data (PII/SPII) is confidential/private.	*All employees have access to companies PII / SPII*
☑	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.	*Controls done by IT Dep*
☐	☑	Data is available to individuals authorized to access it.	*Ensured by IT Dep Controls*

Recommendations :

There are several elements to prioritize according to security principles :

- Access control : apply this principle to implement separation of duties to restrict access to sensitive data
- Data encryption : for credit card information to also protect another sensitive data
- Backup and recovery : Implement regular backups and create a disaster recovery plan to prevent permanent data loss.
- Password management : strengthen the password policy and implement multi-factor authentication (MFA) could be a great improvement.
- Intrusion detection : implement an IDS (Intruder Detection System) can be used to detect suspicious network activity and security breaches